CRA & IEC 62443 Gap Analysis – Networked Refrigeration Controller

1. Purpose and scope

This self-study example checks a fictional networked refrigeration controller against the EU Cyber Resilience Act (CRA, Regulation (EU) 2024/2847) and IEC 62443, and finds 11 gaps, 7 of them high priority. The product, its current state and all findings are invented to practise the method; they describe no real company or product.

Example product: "RC-100" refrigeration unit controller

- Embedded Linux main processor plus a microcontroller for fan and valve control
- Ethernet with Modbus TCP and BACnet/IP to the customer's building management system
- Web interface for configuration and local diagnostics
- Cloud connection over MQTT for remote monitoring by the manufacturer's service team
- Firmware updates uploaded through the web interface
- Installed at customers in food retail, pharma and data centres; expected service life 15+ years

Method: for each CRA essential requirement (Annex I), I mapped the matching IEC 62443-4-1 practice or IEC 62443-4-2 foundational requirement, described an assumed typical current state of a legacy product, and proposed a measure with a priority (High / Medium / Low) based on exposure and effort.

2. CRA applicability and classification

The RC-100 is in scope of the CRA, most likely as a default-category product that can use self-assessment (Module A). This must be confirmed against Annexes III and IV.

- **In scope:** it is a product with digital elements with a network connection, placed on the EU market. No sector law (e.g. medical devices, vehicles) excludes it.
- **Category:** it is not obviously an "important" (Annex III) or "critical" (Annex IV) product, because it is an application controller, not a router, firewall or security component. Assumption: default category.
- **Conformity route:** default category allows internal control (Module A). If it were Annex III class I, Module A would only be allowed with harmonised standards applied.
- **Other legislation to check:** the Machinery Regulation (EU) 2023/1230 if part of a machine; the Radio Equipment Directive and EN 18031 if a Wi-Fi variant is added.
- **Key dates:** reporting obligations (Article 14) apply since 11 September 2026, also for products already on the market; full application from 11 December 2027, after which CE marking requires CRA conformity.

3. Gap analysis

The biggest gaps are unsigned firmware updates, default passwords, and the missing SBOM and vulnerability handling process. FR = foundational requirement of IEC 62443-4-2; practices (SR, SD, SVV, DM, SUM, SG) are from IEC 62443-4-1.

#	CRA requirement	IEC 62443	Assumed current state	Proposed measure	Priority
1	Annex I Part I (2)(b) secure by default; (j) limit attack surface	FR1, FR7; 4-1 SD, SG	Default password admin/admin; Telnet and FTP enabled	Unique password per device or forced change at first login; HTTPS only; unused services off by default	High
2	Part I (2)(d) protection from unauthorised access	FR1, FR2; 4-1 SG	One shared admin account; Modbus TCP has no authentication	Role-based accounts and login rate limiting; Modbus limitation documented, with network segmentation (zones and conduits, IEC 62443-3-2) in the security guideline	High
3	Part I (2)(e) confidentiality ; (f) integrity	FR3, FR4	Web interface over HTTP; cloud certificates not validated	TLS 1.2 or higher everywhere; device certificate; server certificate validation	High
4	Part I (2)(c) security updates; Part II (7) secure distribution	FR3; 4-1 SUM	Unsigned update file uploaded via web interface	Signed firmware, signature check before install, anti-rollback, A/B partitions with fallback	High

#	CRA requirement	IEC 62443	Assumed current state	Proposed measure	Priority
5	Part I (2)(f) integrity; (k) reduce incident impact	FR3 (boot integrity)	No secure boot	Chain of trust from boot ROM where the hardware supports it; otherwise document residual risk and plan a hardware root of trust for the next revision	Medium
6	Part I (2)(j) limit attack surface	FR2, FR7	UART debug console gives a root shell	Disable or lock debug interfaces in production	Medium
7	Part I (2)(l) recording of security events	FR2, FR6	Only basic system logs	Log logins, configuration changes and updates; user can opt out	Medium
8	Part I (2)(m) secure data removal	FR4	Factory reset keeps credentials	Reset wipes credentials, keys and customer data	Low
9	Part II (1) to (3) identify, remediate and test vulnerabilities	4-1 DM, SVV	No SBOM; no vulnerability monitoring	CycloneDX SBOM generated in the build (e.g. Yocto, Syft); continuous monitoring against CVE sources; VEX for "not affected"	High
10	Part II (4) to (6) disclosure and contact	4-1 DM	No public security contact; no	Security contact and coordinated	High

#	CRA requirement	IEC 62443	Assumed current state	Proposed measure	Priority
	point; Article 14 reporting		reporting process	vulnerability disclosure policy; process for 24 h / 72 h / 14-day reports via the ENISA single reporting platform	
11	Article 13 risk assessment; Annex VII technical documentation	4-1 SR, SD, SVV	No TARA; no security requirements	Threat model and risk assessment (STRIDE, attack trees); security requirements; penetration test and fuzzing of Modbus and the web interface before release	High

4. Roadmap

Process work comes first, because reporting duties already apply since 11 September 2026; product fixes follow, and conformity work must close before 11 December 2027.



CRA roadmap · 3 phases, 2 key dates

Phase 3 depends on the first two: the technical documentation needs the TARA results and the fixed product.

5. Open points to verify

- Final category check against Annexes III and IV, and the Commission's implementing act describing those product categories.
- Status of the CRA harmonised standards (CEN/CENELEC) and how far IEC 62443-4-1 and 4-2 can be used to show conformity.
- Support period: at least 5 years under the CRA, but should match the 15+ year service life of the product.
- Whether customers expect an IEC 62443 certification (for example ISASecure SDLA for the development process).
- Modbus TCP: accept as a documented protocol limitation, or offer Modbus/TCP Security (with TLS) in a later version.

6. References

- Regulation (EU) 2024/2847 – Cyber Resilience Act (EUR-Lex)
- IEC 62443-4-1:2018 – Secure product development lifecycle requirements
- IEC 62443-4-2:2019 – Technical security requirements for IACS components
- IEC 62443-3-2:2020 – Security risk assessment for system design (zones and conduits)
- BSI TR-03183 – Cyber resilience requirements for manufacturers and products (Part 2: SBOM)
- ISO/SAE 21434:2021 – Automotive cybersecurity engineering (source of the TARA method used)